

# IAM Access Risk Audit Report

Prepared by: Senior IAM & GRC Security Auditor

Review Type: Automated Access Review — Identity & Access Management (IAM)

Audience: Information Security, Compliance, and IT Leadership

Classification: Confidential

---

## Executive Summary

The following findings were identified during an automated access review of active system records across Finance and HR departments. Four (4) access risk findings were detected, comprising one (1) Critical, one (1) High, and two (2) Medium severity issues. Each finding represents a potential violation of least-privilege principles, joiner-mover-leaver (JML) process controls, or account lifecycle management requirements. Immediate and near-term remediation actions are required to reduce organizational exposure and maintain compliance with applicable regulatory frameworks.

---

## Detailed Findings

---

### ***FINDING: [CRITICAL] — mgarcia***

#### RISK:

User account \*mgarcia\*, classified as a Finance Analyst with Standard access, remains active within the organization's systems despite the user's employment having been terminated. The persistence of an active system record for a terminated individual represents a direct failure in the organization's user offboarding and account lifecycle management controls. Terminated user accounts that remain enabled constitute one of the most significant identity-related attack vectors, as these accounts are no longer monitored by an active employee and may be exploited by malicious insiders, former employees, or external threat actors who have obtained the credentials. The absence of a timely deprovisioning action suggests a breakdown in the integration between Human Resources termination workflows and IAM provisioning processes.

## IMPACT:

From a business perspective, this finding presents an immediate and unacceptable risk of unauthorized access to sensitive financial data, including potentially material non-public information, general ledger systems, or payment processing platforms. In a banking or healthcare environment, the consequences of exploitation could include financial fraud, data exfiltration, or regulatory sanctions. From a compliance standpoint, the continued existence of this account without a legitimate business justification constitutes a probable control deficiency under multiple regulatory frameworks. This finding is likely to be cited as a material weakness during external audits and could trigger mandatory reporting obligations depending on the client's regulatory environment.

## REMEDIATION:

1. Immediate (within 24 hours): Disable and lock the \*mgarcia\* account across all systems, including Active Directory, application-layer access, VPN, and any privileged access management (PAM) tooling.
2. Short-Term (within 5 business days): Conduct a full access audit of all systems \*mgarcia\* had access to, reviewing authentication logs for any activity occurring after the recorded termination date. Escalate any post-termination activity to the Security Operations Center (SOC) and Legal/Compliance teams immediately.
3. Process Improvement: Conduct a root cause analysis to determine why the account was not deprovisioned at the time of termination. Implement or enforce automated, triggered deprovisioning workflows that are initiated upon HR system termination events, with defined SLAs (e.g., account disabled within 24 hours of termination).
4. Verification: Confirm full deprovisioning via a reconciliation report between the HR system of record and the IAM directory within 30 days.

## FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2 (Account Management) — Requires organizations to disable accounts when no longer required, including upon termination; AC-2(3) — Mandates automatic disabling of inactive or terminated accounts; PS-4 (Personnel Termination) — Requires immediate revocation of system access upon termination.
- PCI-DSS v4.0: Requirement 7.2.5 — All user accounts and access rights must be reviewed and managed; Requirement 8.1.4 — Accounts for terminated users must be removed or disabled immediately upon termination.
- SOC 2 (Trust Services Criteria): CC6.2 — Prior to issuing system credentials and granting access, the entity registers and authorizes new internal and external users; CC6.3 — The entity removes access to protected information assets when appropriate.
- HIPAA Security Rule: §164.308(a)(3)(ii)(C) — Termination procedures must include processes for revoking access to ePHI upon employee separation (applicable if organization handles protected health information).

---

**FINDING: [HIGH] — rlee**

## RISK:

User \*rlee\*, a contractor within the Finance department, has been identified as holding privileged-level system access. Contractors, by the nature of their engagement, represent a higher-risk user population due to their temporary affiliation, reduced organizational oversight, and the likelihood that their access spans multiple client or employer environments simultaneously. The assignment of privileged access to a contractor account — absent documented, time-bound, and formally approved justification — violates the principle of least privilege and the principle of need-to-know. Privileged access in financial systems may encompass the ability to modify configurations, access sensitive records, execute transactions, or override system controls, all of which represent elevated risk when held by a non-permanent staff member.

#### IMPACT:

In a banking or healthcare context, contractor accounts with privileged access represent a significant insider threat risk and a third-party risk management concern. Should the contractor's credentials be compromised, or should the contractor act maliciously, the blast radius of potential damage is substantially greater than that of a standard user. Additionally, many regulatory frameworks impose specific requirements around privileged access management and third-party access governance. The existence of this configuration without documented exception approval is likely to constitute a control gap finding in any external audit or regulatory examination. This may also implicate the organization's third-party risk management (TPRM) program if the contractor is employed through a staffing vendor.

#### REMEDIATION:

1. Immediate (within 48 hours): Initiate a formal access justification review for \*rlee\*. Engage the account owner or business sponsor to determine whether privileged access is operationally required.
2. Short-Term: If privileged access cannot be formally justified with documented business need and management approval, immediately downgrade \*rlee\*'s access to Standard level commensurate with the Analyst or Contractor role profile. Privileged access, if retained, must be time-bound and subject to enhanced monitoring.
3. Privileged Access Controls: Enroll \*rlee\* in the organization's Privileged Access Management (PAM) solution (e.g., CyberArk, BeyondTrust) if not already enrolled, enforcing session recording, just-in-time (JIT) access provisioning, and multi-factor authentication (MFA) for all privileged sessions.
4. Policy Enforcement: Review and update the Contractor Access Policy to explicitly prohibit the assignment of privileged access to contractor accounts without documented exception approval from the CISO or delegated authority, with mandatory periodic review cycles.

#### FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2 (Account Management) — Requires role-based access commensurate with job function; AC-6 (Least Privilege) — Mandates that users be granted only the access required to perform their duties; AC-6(5) — Requires privileged accounts to be restricted to designated individuals; IA-2(1) — MFA required for privileged access.
- PCI-DSS v4.0: Requirement 7.2.1 — Access control systems must restrict access based on need-to-know and least privilege; Requirement 8.2.2 — Group, shared, or generic accounts must be managed and privileged access controlled; Requirement 12.8 — Third-party/contractor access must be managed and monitored.
- SOC 2 (Trust Services Criteria): CC6.3 — Access is removed or restricted when no longer appropriate; CC6.6 — Logical access security measures are implemented to protect against threats from sources outside the system boundaries (inclusive of third parties).

- HIPAA Security Rule: §164.308(a)(4)(ii)(B) — Access authorization procedures must ensure only authorized personnel access ePHI; §164.308(a)(1)(ii)(D) — Information system activity review, particularly relevant for privileged users.

---

***FINDING: [MEDIUM] — tjones***

**RISK:**

User \*tjones\*, an HR Manager with Standard access, has not logged into the system for a period exceeding ninety (90) days, meeting the organization's threshold for classification as a dormant account. Dormant accounts represent a persistent and frequently underestimated security risk. An account that is no longer actively used by its owner may not be subject to the same level of behavioral monitoring as active accounts, making it an attractive target for compromise without immediate detection. In the context of an HR Manager role, even Standard access may include the ability to view, modify, or export sensitive employee records, salary information, or benefits data — all of which are considered sensitive personal data subject to privacy regulations.

**IMPACT:**

An undetected compromise of a dormant HR Manager account could result in unauthorized access to sensitive employee personally identifiable information (PII), potentially triggering data breach notification obligations under applicable state or federal privacy laws. Within a healthcare organization, if HR systems are integrated with workforce management platforms connected to ePHI, this risk is compounded. From a compliance perspective, the existence of a dormant account without documented review or business justification represents a gap in the organization's periodic access review controls. This finding may be cited as a deficiency in user access recertification processes during SOC 2 Type II audits or HIPAA assessments.

**REMEDIATION:**

1. Short-Term (within 5 business days): Initiate a verification inquiry with \*tjones\*'s direct manager or HR leadership to confirm the user's current employment status and whether continued system access is operationally required.
2. If Active and Access Required: Re-enable or confirm active status. Require the user to complete a reauthentication event and verify that assigned access remains appropriate for their current role. Document the business justification for account retention.
3. If Access No Longer Required: Disable the account immediately and flag for deprovisioning in the next access review cycle.
4. Automated Controls: Implement or enforce an automated dormant account detection and suspension policy, whereby accounts with no login activity for 60 days generate an alert and accounts exceeding 90 days are automatically suspended pending review.

**FRAMEWORKS:**

- NIST 800-53 Rev. 5: AC-2 (Account Management) — Requires periodic review of accounts and disabling of accounts that are no longer active or necessary; AC-2(3) — Automated disabling of inactive accounts after a defined period.
- PCI-DSS v4.0: Requirement 8.1.4 — User accounts inactive for more than 90 days must be either removed or disabled.
- SOC 2 (Trust Services Criteria): CC6.2 — Credentials are issued and managed appropriately; CC6.3 — Access is removed or restricted when no longer appropriate; A1.1 — Availability and access recertification processes must be evidenced.
- HIPAA Security Rule: §164.308(a)(3)(ii)(B) — Workforce clearance procedures must ensure access is appropriate; §164.308(a)(5)(ii)(C) — Log-in monitoring procedures must be in place and reviewed.

---

### ***FINDING: [MEDIUM] — hkim***

#### **RISK:**

User \*hkim\*, a contractor within the Finance department holding Standard access, has not logged into the system for a period exceeding ninety (90) days. This finding is particularly noteworthy because it involves a contractor account, which inherently carries a higher risk profile than permanent employee accounts due to the time-limited and variable nature of contractor engagements. Contractor accounts are frequently created for specific projects or engagements and are at elevated risk of being overlooked during regular access review cycles following the conclusion of the engagement. The dormancy of this account raises questions as to whether the underlying contractor engagement remains active and whether the access was formally reviewed at the conclusion of any project deliverable.

#### **IMPACT:**

Beyond the standard risks associated with dormant accounts — including unauthorized use and reduced detectability of compromise — a dormant contractor account in the Finance department presents specific concerns around potential access to financial reporting systems, accounts payable/receivable platforms, or treasury management tools. In a regulated financial institution, unauthorized or unmonitored access to these systems could constitute a Sarbanes-Oxley (SOX) control deficiency, a PCI-DSS access control violation, or an internal audit finding. Additionally, if the contractor's engagement has concluded and the account has not been deprovisioned, this indicates a failure in the third-party offboarding process, distinct from but related to the employee offboarding gap identified in the \*mgarcia\* finding.

#### **REMEDIATION:**

1. Immediate (within 48 hours): Verify with the contractor's business sponsor whether the \*hkim\* engagement is still active and whether system access is currently required.
2. If Engagement Concluded: Disable and deprovision the account immediately. Document the date of engagement conclusion and the date of deprovisioning for audit trail purposes.

3. If Engagement Ongoing: Assess whether the lack of system login reflects a process or access issue that may be preventing the contractor from using assigned systems. Confirm access remains appropriate and re-validate against current scope of work.

4. Third-Party Access Governance: Review and enforce the organization's contractor access policy to require time-bound access provisioning with hard expiration dates aligned to contract end dates. Implement automated account expiration tied to contract end dates sourced from the vendor management or procurement system.

#### FRAMEWORKS:

- NIST 800-53 Rev. 5: AC-2 (Account Management) — Includes management of temporary and contractor accounts with defined expiration conditions; AC-2(2) — Requires automated removal or disabling of temporary accounts after a defined period; PS-7 (External Personnel Security) — Requires access controls for contractors to be equivalent to those for organizational personnel.

- PCI-DSS v4.0: Requirement 8.1.4 — Inactive accounts must be disabled after 90 days; Requirement 12.8.5 — Monitoring of third-party access to cardholder data environments.

- SOC 2 (Trust Services Criteria): CC6.3 — Access removed or restricted when no longer appropriate; CC9.2 — The entity manages vendor and business partner risk, including logical access granted to third parties.

- HIPAA Security Rule: §164.308(a)(3) — Workforce security procedures applicable to contractors and business associates with system access; §164.308(b)(1) — Business associate agreements and access governance for third parties handling ePHI.

---

## Summary Risk Matrix

| Finding | User | Severity | Department | Key Risk | Recommended Action |

|---|---|---|---|---|---|

| Terminated Active Account | mgarcia | ■ Critical | Finance | Unauthorized post-termination access | Disable immediately; audit login history |

| Contractor Privileged Access | rlee | ■ High | Finance | Excessive privilege for third party | Review & reduce to least privilege; enroll in PAM |

| Dormant Employee Account | tjones | ■ Medium | HR | Unmonitored access to sensitive HR data | Verify status; suspend if unneeded |

| Dormant Contractor Account | hkim | ■ Medium | Finance | Potential lapsed contractor engagement | Verify engagement; deprovision if concluded |

---

## Auditor Recommendations — Systemic Controls

In addition to the individual remediations noted above, the audit team recommends the following systemic improvements to prevent recurrence:

1. Automate HR-to-IAM Integration: Termination events in the HRIS should automatically trigger account disablement workflows with a defined SLA, eliminating manual dependencies in the offboarding process.
2. Implement Time-Bound Contractor Access: All contractor accounts should be provisioned with hard expiration dates aligned to contract end dates, with automated expiration enforcement.
3. Enforce Quarterly Access Recertification: Business owners should formally recertify all direct reports' access on a quarterly basis, with documented evidence retained for audit purposes.
4. Privileged Access Management (PAM) Enforcement: All privileged accounts, including any exceptions granted to contractors, must be enrolled in a PAM solution with session recording and just-in-time access controls.
5. Dormant Account Automation: Deploy automated detection for accounts inactive beyond 60 days (alert) and 90 days (auto-suspend), with a defined review and reactivation workflow.

---

\*This report contains confidential audit findings intended solely for the use of the named client's authorized personnel. Findings should be remediated in accordance with the recommended timelines and evidenced for inclusion in the next audit cycle.\*